SOC Fundamentals and Operations

Cybersecurity Internship – CyArt

Date: March 12, 2026.

Prepared by: Yogesh Kumar Agrahari

Authorized scan on personal test environment

Table of Contents

1. Introduction
2. SOC Fundamentals and Operations
3. Security Monitoring Basics
4. Log Management Fundamentals
5. Security Tools Deep Dive
6. Core Security Concepts
7. Security Operations Workflow
8. Incident Response Fundamentals
9. Documentation Standards
10. PRACTICAL APPLICATION SECTION
11. References

1. Introduction

This document is a hands-on companion guide to the SOC Fundamentals course. Every tool, command, and workflow is broken down step by step, with annotated screenshots from a real lab environment. Use this as your primary reference when setting up your mini-SOC lab.

2. SOC Fundamentals and Operations:

A Security Operations Centre (SOC) is a centralized team responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats in real time. The SOC serves as the nerve centre of an organization's security posture.

2.1 Purpose of a SOC:

- Proactive Threat Detection: Continuously monitor networks, systems, and applications for indicators of compromise (IOC).
- Incident Response: Contain, investigate, and remediate security incidents in a timely manner.
- Continuous Monitoring: Operate 24/7 using automated tools and human analysts to ensure no threat goes unnoticed.
- Threat Intelligence Integration: Ingest and act on threat feeds to stay ahead of emerging attack patterns.
- Compliance Reporting: Generate audit logs and reports to satisfy regulatory requirements (e.g., GDPR, PCI-DSS, ISO 27001).

2.2 Core Functions:

1. Log Analysis: Parse and query log data from endpoints, servers, firewalls, and cloud environments.
2. Alert Triage: Determine if an alert is a true positive, false positive, or requires escalation.
3. Threat Intelligence Integration: Apply threat feeds (e.g., MISP, AlienVault OTX) to enrich alerts.
4. Vulnerability Management Support: Work alongside VM teams to prioritize patching based on active exploitation.
5. Forensic Investigation: Preserve and analyse digital evidence from compromised systems.

2.3 SOC Roles — Tier Structure:

Role	Responsibility	Skills Required	Experience Level
Tier 1 Analyst	Alert monitoring, first triage, escalation	SIEM basics, log reading, ticket creation	Entry Level (0-2 yrs)
Tier 2 Analyst	Deep investigation, IOC analysis, threat correlation	Malware analysis, network forensics, scripting	Mid Level (2-4 yrs)
Tier 3 Treat Hunter	Proactive threat hunting, red team engagement	Advanced forensics, exploit knowledge, MITRE ATT&CK	Senior (4+ yrs)
Soc Manager	Team leadership, metrics, policy, client reporting	Management, KPIs, security frameworks	5+ years

2.4 Key Frameworks to Study:

• Framework: NIST Cybersecurity Framework (CSF)
◦ Identify → Protect → Detect → Respond → Recover
• Framework: MITRE ATT&CK
◦ A knowledge base of adversary tactics (14 categories), techniques, and sub-techniques based on real
world attack data
◦ Use it to map alerts to attacker behavior — e.g., T1059 = Command & Scripting Interpreter (PowerShell
attacks)
• Framework: Cyber Kill Chain (Lockheed Martin):
◦ Reconnaissance → Weaponization → Delivery → Exploitation → Installation → C2 → Actions

2.5 How to Study This Module:

1. Study the NIST CSF website at nist.gov/cyberframework — free and detailed
2. Explore MITRE ATT&CK Navigator at attack.mitre.org — interactive threat matrix
3. Watch IBM Technology and Microsoft Security YouTube walkthroughs
4. Read the SANS SOC Survey reports — they show real-world SOC structure

2.5 YouTube Resources — SOC Fundamentals:

Channel / Creator	YouTube Search / Link	Key Topics Covered
Professor Messer	youtube.com/c/ ProfessorMesser	Security+ fundamentals, CIA triad, threat models, SOC concepts
John Hammond	youtube.com/ @_JohnHammond	SOC workflow demos, CTF walkthroughs, SOC analyst career guide
IBM Technology	youtube.com/ @IBMTechnology	Enterprise SOC operations, IBM QRadar, threat intelligence
TCM Security	youtube.com/ @TCMSecurityAcademy	SOC analyst course, Tier 1 daily workflow, alert triage
David Bombal	youtube.com/ @davidbombal	MITRE ATT&CK intro, cybersecurity roadmap for beginners

3: Security Monitoring Basics:

GOAL:

Learn how to detect threats using SIEMs, monitor network traffic, and measure the quality of your detections.

Security monitoring is the continuous collection, analysis, and interpretation of data from IT systems to detect suspicious activity, policy violations, and security threats.

3.1 Security Monitoring Objectives:

• Detect anomalous behavior that deviates from normal baselines
• Identify unauthorized access attempts and privilege escalation
• Monitor for policy violations (e.g., USB use, off-hours login)
• Correlate events across multiple systems to find hidden attack patterns

3.2 Core Monitoring Tools:

Tool	Type	Free Option	Primary Use
Splunk	SIEM	Splunk Free (500MB/day)	Log aggregation, correlation, dashboards
Elastic SIEM (ELK)	SIEM	100% Open Source	Full-stack log monitoring, KQL queries
Wazuh	XDR/SIEM	100% Open Source	Endpoint monitoring, FIM, MITRE mapping
Wireshark	Network Analyzer	Free / Open Source	Packet capture and deep traffic analysis
Zeek (Bro)	Network Monitor	Open Source	Network flow logs, DNS, HTTP analysis
Security Onion	Full SOC Platform	Open Source	All-in-one: Suricata + Zeek + Kibana

3.3 Key Monitoring Metrics:

- Mean Time to Detect (MTTD): Average time from a breach occurring to its detection.
- Mean Time to Respond (MTTR): Average time from detection to containment/resolution.
- False Positive Rate: Percentage of alerts that are not actual threats. High rates waste analyst time.
- False Negative Rate: Percentage of real threats that go undetected. High rates are dangerous.
- Alert Volume: Total number of alerts generated per day. Used to track analyst workload.

3.4 How to Learn:

- Set up a home lab with Elastic SIEM (free, open-source) and connect a Windows VM as an endpoint.
- Download the Boss of the SOC (BOTS) dataset from Splunk and practise analysis on real attack data.
- Analyse sample PCAP files in Wireshark to identify common attack patterns (port scans, brute force).
- Complete Elastic SIEM's free online training modules at learn.elastic.co.

3.5 YouTube Resources — Security Monitoring:

Channel / Creator	YouTube Search / Link	Key Topics Covered
Security Onion Solutions	youtube.com/ @SecurityOnion	Full SOC setup, Suricata rules, Zeek, Kibana dashboards
Elastic	youtube.com/@elastic	Elastic SIEM tutorials, KQL queries, detection rules
MyDFIR	youtube.com/@MyDFIR	Building home SOC lab, Wazuh setup, alert detection
NetworkChuck	youtube.com/ @NetworkChuck	Wireshark packet analysis, network monitoring labs
Hak5	youtube.com/@Hak5	Network traffic captures, intrusion detection demos

4. Log Management Fundamentals:

GOAL
Master the full log lifecycle: collection, normalization, storage, and querying. Logs are the lifeblood of a SOC

Logs are the foundational data source for all SOC operations. Effective log management ensures that data is collected, normalized, stored, retained, and queried efficiently.

4.1 Log Lifecycle:

Stage	What Happens	Tools Used
Collection	Gather logs from endpoints, servers, f irewalls, apps	Fluentd, Logstash, Filebeat, Syslog
Normalization	Convert diverse formats to a single standard (JSON/CEF)	Logstash filters, Cribl, NXLog
Storage	Index logs for fast search; raw logs retained for compliance	Elasticsearch, Splunk indexers, S3
Retention	Define how long logs are kept (legal: typically 1-7 years)	Lifecycle policies in Elastic/Splunk
Analysis	Query, correlate, and alert on log data	KQL, SPL (Splunk), SQL, Sigma rules

4.2 Critical Log Types to Know:

- Windows Event Logs — Top IDs to memorize:
- 4624 = Successful logon | 4625 = Failed logon (brute force detection)
- 4648 = Logon with explicit credentials | 4720 = New user account created
- 4688 = New process created | 7045 = New service installed (malware persistence)
- 4776 = Credential validation attempt | 4732 = Member added to privileged group
- Linux Syslog / Auth.log:
- Failed SSH: 'Failed password for [user] from [IP]'
- Sudo usage: 'sudo: [user] : TTY=pts/0 ; COMMAND=/bin/bash'
- Web Server Logs (Apache/Nginx):
- HTTP 200 = Success | 403 = Forbidden | 404 = Not Found | 500 = Server Error
- Watch for SQLi patterns: GET /page.php?id=1'OR'1'='1

- Firewall / Network Logs:
- Look for port scans (many connections to different ports from one IP)
- Unusual outbound connections on non-standard ports (data exfiltration)

4.3 Key Windows Event IDs:

Event ID	Description	Why It Matters
4624	Successful logon	Baseline for normal login activity.
4625	Failed logon attempt	Repeated failures suggest brute-force attacks.
4648	Logon with explicit credentials	May indicate credential reuse or pass-the-hash.
4672	Special privileges assigned	Elevated rights assigned — watch for privilege abuse.
4688	New process created	Used to detect malicious process execution (e.g., cmd.exe spawned by Office).
4698	Scheduled task created	Attackers create tasks for persistence.
4720	User account created	Unauthorized account creation may indicate compromise.
4776	NTLM authentication attempt	Pass-the-hash and brute-force indicators.
7045	New service installed	Malware often installs as a service for persistence.
1102	Audit log cleared	Attacker covering tracks — high priority alert.

4.4 Practical Task — Log Collection Pipeline:

- Install Fluentd on Ubuntu VM:
- sudo gem install fluentd --no-document
- sudo fluentd --setup /etc/fluent
- Configure to collect Syslog from /var/log/syslog
- Test log generation:
- logger 'SOC Test Message - Alert Level HIGH'
- Forward output to Elastic SIEM and verify in Kibana Discover

4.5 KQL Query Practice (Elastic / Azure Sentinel):

KQL (Kusto Query Language) is used in both Elastic and Microsoft Sentinel. Master these patterns:

- Find all failed logins (Event ID 4625): source = 'security-login-*' AND EventID = 4625 | stats count by SourceIP
- Detect brute force (5+ failures in 5 mins):EventID:4625 | bucket @timestamp span=5m | having count > 5
- Find process creation events on a specific host: EventID:4688 AND hostname:'WORKSTATION01' | sort @timestamp desc

- Detect new user creation: EventID:4720 | fields +TargetUserName, SubjectUserName, @timestamp

4.6 YouTube Resources — Log Management:

Channel Creator	YouTube Search / Link	Key Topics Covered
James Briggs (KQL)	Search: 'KQL tutorial Azure Sentinel'	KQL from scratch, Sentinel detection rules, log queries
Splunk	youtube.com/@Splunk	SPL queries, log parsing, dashboards, Splunk SIEM full course
Fluentd Official	Search: 'Fluentd tutorial log pipeline'	Fluentd config, log routing, output plugins
John Strand (BHIS)	youtube.com/ @BlackHillsInfoSec	Log analysis war stories, detection engineering

5. Security Tools Deep Dive:

GOAL
Get hands-on with the essential tools every SOC analyst uses: SIEM, EDR, IDS/IPS, and Vulnerability Scanners.

SOC analysts work with a wide range of specialized tools. Understanding each tool's purpose, capabilities, and limitations is essential for effective threat detection and response.

5.1 Tool Categories & Best Free Options:

- SIEM (Security Information & Event Management):
- Splunk Free Edition (500MB/day limit) — Industry standard, must-know
- Wazuh — Open source, full-featured XDR/SIEM with MITRE ATT&CK mapping
- Elastic SIEM — Powerful free option, KQL-based, great for beginners
- EDR (Endpoint Detection & Response):
- Wazuh agent — Monitors file integrity, processes, network connections
- Velociraptor — Open source endpoint forensics and hunting platform
- IDS/IPS (Intrusion Detection/Prevention):
- Snort 3 — Industry-standard rule-based IDS, free, widely deployed
- Suricata — High-performance IDS/IPS with deep protocol support
- Vulnerability Scanners:
- Nessus Essentials — Free for 16 IPs, professional-grade scanning
- OpenVAS (Greenbone) — Fully open source vulnerability management
- Endpoint Visibility:
- Osquery — SQL-based endpoint querying (Facebook-developed, open source)

5.2 Hands-On Lab: Snort IDS:

- Install Snort 3 on Ubuntu VM:
- sudo apt-get install snort -y
- Write a custom rule to detect requests to a malicious domain:
- alert tcp any any -> any 80 (msg:"Malicious Domain"; content:"malicious.com"; http_uri;

- sid:1000001;)
- Place rule in /etc/snort/rules/local.rules
- Start Snort in IDS mode:
- sudo snort -A console -c /etc/snort/snort.conf -i eth0
- Test by generating traffic:
- curl http://malicious.com
- You should see an alert printed to console

5.3 Hands-On Lab: Nessus Vulnerability Scan:

- Download Metasploitable2 (intentionally vulnerable Linux VM) — free from SourceForge
- Install Nessus Essentials — register at tenable.com (free for 16 IPs)
- Create a Basic Network Scan targeting your Metasploitable2 IP
- Run the scan and wait (~15-30 minutes)
- Go to Results > Vulnerabilities — sort by CVSS score descending
- Document the top 3 critical vulnerabilities with CVE numbers and remediation steps

5.4 Hands-On Lab: Osquery Endpoint Monitoring:

- Install Osquery on a Windows VM from osquery.io
- Open osqueryi (interactive shell) and run:
- SELECT name, pid, path FROM processes WHERE name LIKE '%powershell%';
- SELECT * FROM users;
- SELECT * FROM listening_ports;
- Create a harmless 'suspicious' batch file to simulate malware:
- echo @echo off > suspicious.bat && echo echo HACKED >> suspicious.bat
- Run it, then immediately query Osquery:
- SELECT name, pid, cmdline FROM processes ORDER BY start_time DESC LIMIT 10;

5.5 How to Learn:

- Access the Splunk Free tier at splunk.com and ingest sample data from the Boss of the SOC (BOTS) dataset.
- Deploy Wazuh using Docker or a pre-built OVA to get a full SIEM + EDR environment for free.
- Configure Snort rules in a sandbox to block and detect mock attacks from Metasploitable2.
- Run a Nessus Essentials scan against a vulnerable VM (Metasploitable, DVWA) and review the output.

5.5 Practical Tasks:

```
# Install Snort sudo apt-get install snort -y  # Add rule to
/etc/snort/rules/local.rules: alert tcp any any -> any 80 (msg:"Malicious Domain
Detected"; content:"malicious.com"; http_uri; sid:1000001; rev:1;)  # Test the
rule: curl http://malicious.com  # Check Snort alert log: cat /var/log/snort/alert
```

Nessus Vulnerability Scan

- Download and install Nessus Essentials (free for up to 16 hosts).
- Create a new basic network scan and target your Metasploitable2 VM IP.
- Run the scan, export the report as a PDF, and identify the top 3 vulnerabilities by CVSS score.
- Research each vulnerability on the NVD (nvd.nist.gov) and note recommended mitigations.

Osquery Endpoint Visibility
Install Osquery on a Windows or Linux VM and run the following queries:

```
-- List all running processes SELECT pid, name, path, cmdline FROM processes;  -
- Find listening network connections SELECT pid, local_address, local_port,
remote_address, remote_port FROM process_open_sockets WHERE state = 'LISTEN';  -
- List recently modified files SELECT path, mtime, size FROM file WHERE
directory = 'C:\\Users\\' AND mtime > (strftime('%s','now') - 3600);
```

6. Core Security Concepts:

GOAL
Build a solid foundation in security theory that underpins every SOC decision: CIA, zero trust, defense in depth.

A solid grasp of foundational security principles ensures analysts can contextualize alerts, prioritize threats, and communicate clearly with technical and non-technical stakeholders.

6.1 The CIA Triad:

Principle	Definition	SOC Example
Confidentiality	Data is only accessible to authorized parties	Detecting unauthorized file access or data exfiltration over DNS
Integrity	Data has not been altered without authorization	File Integrity Monitoring (FIM) alerts when system files change
Availability	Systems are accessible when needed by authorized users	DDoS detection and mitigation, uptime monitoring

6.2 Threat vs. Vulnerability vs. Risk:

- Definition: Threat: Any potential danger that could exploit a vulnerability. Example: Ransomware group targeting healthcare
- Definition: Vulnerability: A weakness in a system, process, or control. Example: Unpatched Apache web server (CVE-2021-41773)
  Definition: Risk: The likelihood and impact of a threat exploiting a vulnerability. Risk = Threat x Vulnerability x Impact
- Example: Real Case Study — Equifax Breach (2017):
- Threat: Nation-state attackers targeting credit data
- Vulnerability: Unpatched Apache Struts (patch available 2 months before breach)
- Result: 147 million records stolen. Could have been prevented with basic patch management

6.3 Defense-in-Depth Strategy:

Defense-in-depth means layering multiple security controls so that if one fails, others still protect the organization. A SOC monitors ALL layers:
• Layer 1 — Perimeter: Firewalls, WAFs, IPS block obvious attacks at the edge
• Layer 2 — Network: Segmentation, VLANs, network monitoring (Zeek, Suricata)
• Layer 3 — Endpoint: EDR agents, antivirus, application whitelisting
• Layer 4 — Application: Input validation, patch management, code review
• Layer 5 — Data: Encryption at rest and in transit, DLP (Data Loss Prevention)
• Layer 6 — User: MFA, privileged access management, security awareness training

6.4 Zero Trust Architecture:

Zero Trust principle: 'Never trust, always verify.' Every user and device must prove identity and authorization for
every resource, every time — even inside the network perimeter.
• Core principle: No implicit trust based on network location
• Micro-segmentation: Limit lateral movement even after breach
• Continuous verification: Re-authenticate sessions, check device health
• SOC relevance: Generates more authentication logs to monitor, but also better detects lateral Movement

6.5 Common Attack Types:

Attack Type	Description	SOC Detection Method
Phishing	Deceptive emails designed to steal credentials or install malware.	Email gateway logs, user reports, proxy logs for malicious URLs.
Brute Force	Repeated login attempts to guess passwords.	SIEM alert on 5+ Event ID 4625 in 1 minute from same IP.
Ransomware	Malware that encrypts files and demands payment.	File integrity monitoring, mass write events, C2 traffic.
SQL Injection	Injecting malicious SQL into web forms to access databases.	Web application firewall (WAF) logs, HTTP 500 errors, DB error logs.
DDoS	Flooding a service with traffic to make it unavailable.	NetFlow data, sudden spike in inbound traffic volume.
Lateral Movement	Attacker moving between systems after initial compromise.	Unusual authentication between internal systems, PsExec usage.
Data Exfiltration	Unauthorized transfer of sensitive data out of the network.	DNS tunnelling logs, large outbound transfers, C2 beacon patterns.

6.6 How to Learn

Use Anki flashcards to memorize key terms and Event IDs.
Study real breach case studies: Equifax (2017), SolarWinds (2020), Colonial Pipeline (2021).
Take the CompTIA Security+ or Google Cybersecurity Certificate as structured learning paths.

7: Security Operations Workflow:

GOAL
Learn the exact step-by-step workflow that SOC analysts follow from the moment an alert fires to incident closure.

The SOC workflow defines how an analyst processes an alert from detection through resolution. A consistent, well-documented workflow reduces response times and ensures no steps are missed.

7.1 The SOC Alert Lifecycle:

Step	Stage	Analyst Action	Tools Used
Step 1	Detection	SIEM generates an alert based on correlation rule	Splunk / Wazuh / Elastic
Step 2	Triage	Analyst reviews alert: Is it a true positive or false positive?	SIEM dashboard, threat intel
Step 3	Investigation	Correlate logs, hunt for related IOCs, check MITRE ATT&CK mapping	Kibana, VirusTotal, TheHive
Step 4	Escalation	If confirmed threat: escalate to Tier 2/3 with full evidence	Ticketing system (Jira/ServiceNow)
Step 5	Containment	Isolate affected system, block malicious IP/hash, disable account	EDR console, firewall ACLs
Step 6	Eradication	Remove malware, patch vulnerability, reset credentials	EDR, patch management
Step 7	Recovery	Restore system from backup, confirm clean state, monitor	Backup tools, SIEM
Step 8	Documentation	Write incident report, update runbooks, lessons learned	Word, Confluence, TheHive

7.2 Alert Triage — How to Prioritize:

Not all alerts are equal. Use this priority matrix to decide what to investigate first:
- Severity: Critical (P1) — Respond immediately:
  - Active ransomware, domain admin compromise, data exfiltration in progress
- Severity: High (P2) — Investigate within 1 hour:
  - Brute force against admin accounts, lateral movement detected, C2 beacon
- Severity: Medium (P3) — Investigate within 4 hours:
  - Multiple failed logins, unusual outbound traffic, new admin account created
- Severity: Low (P4) — Review within 24 hours:
  - Single failed login, policy violations, non-critical vulnerability scan alerts

7.3 Practical Task: Phishing Email Investigation:

- Receive a phishing report from a user
- Extract email headers — identify source IP, SPF/DKIM/DMARC pass/fail
- Check sender domain age and reputation: search on whois.domaintools.com
- Extract URLs from email body — check on VirusTotal.com and URLScan.io
- Determine if user clicked: check proxy logs for destination domain
- If clicked: check endpoint for download events (Event ID 4688 for new processes)
- Contain: block sender domain in email gateway, isolate endpoint if needed
- Document timeline and all IOCs in your incident ticket

7.4 How to Perform:

- Simulate a phishing incident workflow using TheHive (free, open-source incident response platform).
- Build a flowchart for a phishing email incident response using draw.io or Lucidchart.
- Practice correlating alerts in Elastic SIEM by connecting authentication logs with network logs.

8: Incident Response Fundamentals:

GOAL
Learn the NIST IR lifecycle and practice responding to real attack scenarios like ransomware, phishing, and insider threats.

8.1 NIST SP 800-61 IR Lifecycle:

Phase	Key Activities	Deliverable
1. Preparation	Build IR plan, train team, deploy tools, create playbooks	IR policy, runbooks, team contacts, tool inventory
2. Identification	Detect incident, determine scope, classify severity	Incident ticket, initial timeline, affected assets list
3. Containment	Short-term: isolate. Long-term: patch root cause while preserving evidence	Isolation documentation, forensic copies taken
4. Eradication	Remove threat actor persistence, clean infected systems, close vulnerabilities	Clean bill of health for all affected systems
5. Recovery	Restore to normal ops, monitor closely for re-infection	Systems back online, monitoring enhanced
6. Lessons Learned	Post-mortem within 2 weeks: what happened, what worked, what to improve	Post-mortem report, updated runbooks, rule changes

8.2 YouTube Resources — Incident Response:

Channel / Creator	Key Topics Covered
SANS Institute	NIST IR framework, ransomware IR, live walkthroughs
CrowdStrike	Incident response methodologies, threat hunting techniques
Hacking Simplified	NIST IR phases explained step by step
13Cubed	Windows IR artifacts, memory forensics, disk analysis
DFIR.training	Real ransomware cases broken down by phase

8.3 Types of Security Incidents:

- Malware Infection: Ransomware, spyware, trojans, or worms installed on endpoints.
- Unauthorized Access: An attacker gains access to a system, account, or data without permission.
- Data Breach: Sensitive data is accessed, copied, or exfiltrated by an unauthorized party.
- Denial of Service (DoS/DDoS): A service is made unavailable by flooding it with traffic.
- Insider Threat: A current or former employee misuses access to harm the organization.
- Phishing: A user is deceived into revealing credentials or executing malicious code.
- Supply Chain Attack: An attacker compromises a third-party vendor to reach the target (e.g., SolarWinds).

8.4 IR Playbooks:

Playbooks are pre-defined step-by-step procedures for handling specific incident types. Every SOC should have playbooks for at minimum:

- Phishing email investigation and response.
- Ransomware containment and recovery.
- Brute-force attack investigation.
- Insider threat investigation.
- DDoS mitigation.
- Data exfiltration response.

8.5 How to Learn:

- Read and apply the NIST SP 800-61 Computer Security Incident Handling Guide (free PDF at csrc.nist.gov).
- Conduct tabletop exercises: simulate a ransomware attack on your organization and walk through each IR phase.
- Build your own playbook for a phishing incident using the SANS Incident Handler's Handbook as a template.
- Practice in the TryHackMe SOC Level 1 or Blue Team Labs Online learning platforms.

9. Documentation Standards:

Accurate and thorough documentation is one of the most important — and most overlooked — skills in a SOC. Good documentation enables knowledge transfer, supports legal proceedings, satisfies auditors, and improves future incident response.

9.1 Types of SOC Documentation:

- Incident Reports: A full record of what happened, when, how it was detected, and how it was resolved.
- Runbooks: Step-by-step operational procedures for routine SOC tasks (e.g., how to investigate a brute-force alert).
- Standard Operating Procedures (SOPs): High-level process documents that define how the SOC operates.
- Post-Mortems: Analysis documents produced after a significant incident to identify root cause and prevent recurrence.
- Threat Intelligence Reports: Documentation of threat actor TTPs, IOCs, and recommended defences.
- After-Action Reports (AARs): Summaries produced after tabletop exercises or red team engagements.

9.2 Incident Report Template:

Every security incident should be documented using a consistent template. Below is the standard CyArt incident report structure:

Field	Description / Example
Incident ID	INC-2025-0042
Date / Time (UTC)	2025-06-15 14:32:00 UTC
Detected By	Elastic SIEM — Rule: Brute Force Detection
Analyst Name	J. Smith (Tier 1)
Incident Type	Brute-Force Attack / Unauthorized Access Attempt
Severity	High
Affected Asset(s)	WIN-SRV-01 (192.168.1.50) — Active Directory Server
Source IP(s)	203.0.113.45 (External — GeoIP: Russia)
Description	Elastic SIEM generated an alert for 47 failed RDP login attempts (Event ID 4625) against WIN-SRV-01 in a 5-minute window from a single external IP.
IOCs	IP: 203.0.113.45 | Port: 3389 (RDP) | Username targeted: Administrator
Timeline	14:27 — Attack begins. 14:32 — Alert triggered. 14:35 — Analyst confirmed. 14:40 — IP blocked at perimeter firewall.
Actions Taken	1. IP 203.0.113.45 blocked at firewall. 2. Account lock-out policy reviewed. 3. IT notified to enable NLA on RDP. 4. Ticket escalated to Tier 2 for full investigation.
Resolution	Threat contained. No successful logins observed. Monitoring for 48 hours post-block.

Field	Description / Example
Lessons Learned	RDP should not be exposed to the internet. Recommend restricting to VPN only.

9.3 Documentation Best Practices:

- Use clear, factual language. Avoid ambiguity. Write as if the reader has no prior knowledge of the incident.
- Record timestamps in UTC to avoid timezone confusion across global teams.
- Include evidence references (screenshots, log excerpts, file paths).
- Document negative findings as well — noting that no lateral movement was found is as important as noting what was found.
- Use your organization's ticketing system (e.g., ServiceNow, Jira, TheHive) to maintain a traceable audit trail.

9.4 How to Perform:

- Download the SANS Incident Handler's Handbook and use its templates as a starting point.
- Practice writing a mock incident report for a simulated DDoS attack.
- Build a runbook for responding to a phishing email in a shared team wiki (e.g., Confluence, Notion).

10. PRACTICAL APPLICATION SECTION:

GOAL
Apply everything learned through hands-on tasks, log analysis, dashboards, and alert rules in a real lab environment.

Lab 1: Windows Event Log Analysis

- Filter for Event ID 4625: Failed login attempts. Repeated occurrences from the same source IP indicate a brute-force attack.
- Filter for Event ID 7045: New service installation. Malware frequently installs itself as a Windows service for persistence.
- Filter for Event ID 4688: New process created. Look for cmd.exe or powershell.exe spawned by Office applications — a classic malware indicator.
- Filter for Event ID 1102: Audit log cleared. This is a critical alert — always investigate immediately.

To open Event Viewer and filter logs via the command line:

```
# Export Security log events with Event ID 4625 to a CSV wevtutil qe Security /q:"*[System[EventID=4625]]" /f:text > failed_logins.txt  # Filter by Event ID in PowerShell Get-EventLog -LogName Security -InstanceId 4625 | Export-Csv -Path C:\SOC\brute_force.csv
```

Lab 2: Browser History Forensics with Zimmerman Tools:

Eric Zimmerman's forensic tools are widely used for Windows artifact analysis. LECmd (Link Evidence Command tool) and similar tools parse browser artifacts, shell items, and prefetch files.

- Download all Zimmerman tools from: https://ericzimmerman.github.io
- Use BrowsingHistoryView or ChromeHistoryView to export Chrome history to CSV.
- Search the exported CSV for known malicious domains using IOC lists.

```
# Run LECmd to parse LNK files LECmd.exe -d
C:\Users\%USERNAME%\AppData\Roaming\Microsoft\Windows\Recent -q  # Run
ChromeHistoryView (GUI) or use SQLite to query Chrome history sqlite3
"C:\Users\user\AppData\Local\Google\Chrome\User Data\Default\History" "SELECT
url, title, visit_count FROM urls ORDER BY visit_count DESC LIMIT 50;"
```

Advanced Tasks

Task A — Brute-Force Detection:

- Open your Windows VM and attempt 10 failed logins to a local account.
- Open Event Viewer → Windows Logs → Security.
- Apply a filter for Event ID 4625 and note the Source Network Address field.
- Export the filtered results using wevtutil and save to a CSV file.
- Document your findings using the incident report

> **Expected outcome:** A list of timestamps and source IPs for each failed login. Multiple failures within a short window from the same IP confirm a brute-force attempt.

Task B — Zimmerman Tools Practice:

- Download and run ChromeHistoryView on your lab VM.
- Visit http://test.com and http://malicious-test.example.com in Chrome.
- Re-run ChromeHistoryView and export the history to CSV.
- Search the CSV for both URLs and confirm they appear with accurate timestamps.

Tools Reference:

- Built-in: Windows Event Viewer, PowerShell Get-EventLog, wevtutil CLI.
- Third-party: Eric Zimmerman's Tools, LogParser Lizard, Elastic SIEM, Splunk.
- Linux log tools: grep, awk, journalctl, ausearch (for audit logs).

2. Document Security Events:

Accurate and timely documentation is a core SOC analyst responsibility. All security events — whether confirmed incidents or investigated alerts — must be recorded in a structured format.

2.1 Event Log Template:

Use the following template to document every alert investigated during a shift:

Date/Time (UTC)	Source IP	Event ID	Description	Action Taken
2025-06-15 14:32	192.168.1.10	4625	Multiple failed logins to WIN-SRV-01. 47 attempts in 5 mins.	IP blocked. Ticket INC-2025-0042 opened. Escalated Tier 2.
2025-06-15 15:10	10.0.0.55	7045	New service 'svchost64' created on WKSTN-007. Unusual name.	Process killed. File quarantined. Full forensic investigation initiated.
2025-06-15 16:45	203.0.113.80	4688	cmd.exe spawned by winword.exe on WKSTN-012. Macro execution suspected.	Host isolated. Memory dump taken. Malware analysis in progress.

2.2 How to Perform:

- Create your own event log template in Excel, Google Sheets, or Notion for daily use.
- During each lab exercise, complete a row in your event log as if you were working a real shift.
- Review your logs at the end of each session to identify patterns across events.

> **Important:** Never document sensitive data (passwords, PII, personal user data) in plain text in your event log. Use ticket IDs to reference full investigation records.

Lab 3: Build a SOC Dashboard in Kibana:

A well-configured SOC dashboard gives analysts instant visibility into the security health of the environment. Dashboards should surface the most actionable information at a glance.

3.1 Essential Dashboard Panels:

- Top 10 Source IPs by Alert Volume: Quickly identify the noisiest or most suspicious sources.
- Alert Severity Over Time: Track whether critical/high alerts are increasing or decreasing.
- Frequency of Critical Event IDs: Monitor Event IDs 4625, 4688, 7045, 1102 in real time.
- Geographic Map of Source IPs: Visualize where traffic and alerts originate globally.
- Failed Login Heatmap by Hour: Identify off-hours brute-force patterns.
- Open Incident Tickets by Severity: Track the backlog and ensure SLAs are met.

3.2 Steps to Build in Kibana (Elastic SIEM):

- Open Kibana and navigate to Dashboard → Create Dashboard.
- Click Add Panel → Lens and select the visualization type (bar chart, line chart, data table).
- Set the index pattern to your log source (e.g., winlogbeat-*, filebeat-*).
- Configure filters for specific Event IDs or alert types.
- Save the panel and add it to your SOC dashboard.
- Set the time range to Last 24 hours as the default view.

3.3 Pre-Built Detection Rules:

Instead of writing all detection rules from scratch, leverage community resources:

- Sigma Rules: Generic, vendor-neutral detection rules. Convert to SIEM-specific queries using sigma-cli.
- Elastic Detection Rules: Available at github.com/elastic/detection-rules — ready to import into Elastic SIEM.
- Splunk Security Essentials App: Downloadable from Splunkbase with hundreds of pre-built detections.
- Wazuh Rules: Built-in rules that cover most common attack patterns; customizable in /var/ossec/rules/.

Lab 4: Create Custom Alert Rules in Wazuh:

Alert rules define the conditions under which a SIEM or security tool will generate a notification for analyst review. Well-tuned rules minimize false positives while ensuring real threats are caught.

4.1 Rule Design Principles:

- Specificity: The more specific the rule, the fewer false positives. Include source, destination, frequency, and threshold.
- Threshold-based: Use count thresholds (e.g., 5+ failures in 60 seconds) to reduce noise from single events.
- Correlation: Combine multiple event types to create higher-confidence alerts (e.g., failed login followed by successful login from a new IP).
- Whitelist exclusions: Exclude known-safe IPs, service accounts, and scheduled maintenance windows.

4.2 Creating Rules in Elastic SIEM:

Create a rule to detect 5 or more failed login attempts within 5 minutes:

```
# In Elastic SIEM: Security → Rules → Create New Rule # Rule Type: Threshold #
Index pattern: winlogbeat-* # Query: event.code: 4625  # Threshold: Count of
event.code Greater than or equal to 5 Over user.name, source.ip Time window: 5
minutes  # Severity: High # Risk score: 73
```

4.3 Creating Rules in Wazuh:

Add a custom rule to Wazuh to detect 3 or more failed SSH logins in 2 minutes:

```
<!-- Add to /var/ossec/rules/local_rules.xml --> <group
name="authentication_failed,">    <rule id="100001" level="10"
frequency="3" timeframe="120">     <if_matched_sid>5503</if_matched_sid>
<description>Brute Force: 3+ failed SSH logins in 2
minutes.</description>
<group>authentication_failures,pci_dss_10.2.4,gdpr_IV_35.7.d,</group>
</rule> </group>
```

Restart Wazuh Manager to apply the rule:

```
sudo systemctl restart wazuh-manager
```

4.4 Testing Alert Rules:

Simulating Failed SSH Logins
From a second VM or attacker machine, run:

- Confirm the alert appears in the SIEM/Wazuh dashboard within the configured time window.
- Verify that the alert includes: source IP, targeted username, number of attempts, and timestamp.
- Document the rule's effectiveness in your event log (how quickly did it trigger? Any false positives?).

4.5 Advanced Tasks:

Task A — Correlation Rule:

Create a correlation rule that triggers when: a failed login (Event ID 4625) is followed by a successful login (Event ID 4624) from the same source IP within 10 minutes. This indicates a successful brute-force attack.

Task B — Alert Tuning:

- Run your brute-force detection rule for 24 hours in your lab.
- Note the total number of alerts generated.
- Identify any false positives (e.g., a legitimate script causing login failures).
- Add exclusions to the rule for known-safe IPs and service accounts.
- Re-run for 24 hours and compare the alert volume and quality.

5. Recommended Learning Approach:

The most effective way to build SOC skills is through a combination of structured study, hands-on lab work, and community engagement.

5.1 Build a Home Lab:

A minimal but effective home lab can be built using free tools on a single machine with virtualization:

- Hypervisor: VirtualBox (free) or VMware Workstation Player (free).
- SIEM: Wazuh (free, open-source) — deploy the all-in-one OVA.
- Windows VM: Windows 10/11 evaluation (free 90-day trial from Microsoft) as an endpoint sending logs to Wazuh.
- Linux VM: Ubuntu Server 22.04 (free) for Wazuh manager and Elastic Stack.
- Vulnerable VM: Metasploitable2 or DVWA (Damn Vulnerable Web Application) as attack targets.
- Endpoint Visibility: Osquery installed on the Windows VM for SQL-based querying.

5.2 Use MITRE ATT&CK to Map Skills:

As you work through exercises, map each attack technique to the MITRE ATT&CK framework

(attack.mitre.org):

- T1059: Command and Scripting Interpreter — detected via Event ID 4688 (PowerShell/cmd.exe).
- T1110: Brute Force — detected via Event ID 4625 thresholds in SIEM.
- T1543.003: Create or Modify System Process (Windows Service) — detected via Event ID 7045.
- T1070.001: Clear Windows Event Logs — detected via Event ID 1102.
- T1190: Exploit Public-Facing Application — detected via WAF logs and web server errors.

Final Checklist:

- Lab Setup: Wazuh manager running, agents connected, Elastic SIEM configured
- Log Collection: Fluentd forwarding syslog to Elastic; wevtutil queries tested on Windows
- Snort Rules: Local rules written, tested, and alerts confirmed in /var/log/snort/alert
- KQL Queries: Brute-force and PowerShell detection queries validated in Kibana
- Osquery: Process, port, and file queries run; suspicious process flagged
- MITRE Mapping: All detected techniques mapped to ATT&CK IDs
- Documentation: Incident report filed with all required fields

11. References:

Standards and Frameworks

- **NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide:** https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final
- **MITRE ATT&CK Framework:** https://attack.mitre.org
- **NIST Cybersecurity Framework (CSF):** https://www.nist.gov/cyberframework
- **ISO/IEC 27035 — Security Incident Management:** https://www.iso.org/standard/78973.html

Tools and Platforms:

- **Elastic SIEM (ELK Stack):** https://www.elastic.co/siem
- **Wazuh Open-Source XDR/SIEM:** https://wazuh.com
- **Splunk Free Tier:** https://www.splunk.com/en_us/download.html
- **Osquery:** https://osquery.io
- **Snort IDS:** https://www.snort.org
- **Eric Zimmerman's Forensic Tools:** https://ericzimmerman.github.io
- **MISP Threat Intelligence Platform:** https://www.misp-project.org
- **AlienVault OTX:** https://otx.alienvault.com

Learning Platforms:

- **TryHackMe SOC Level 1:** https://tryhackme.com/path/outline/soclevel1
- **Blue Team Labs Online:** https://blueteamlabs.online
- **LetsDefend:** https://letsdefend.io
- **Splunk Boss of the SOC:** https://bots.splunk.com
- **Hack The Box:** https://www.hackthebox.com
- **NVD Vulnerability Database:** https://nvd.nist.gov

Templates and Handbooks:

- **SANS Incident Handler's Handbook:** https://www.sans.org/white-papers/33901/
- **CISA Incident Response Playbooks:** https://www.cisa.gov/resources-tools/resources/federal-government-cybersecurity-incident-response-playbooks
- **Elastic Detection Rules (GitHub):** https://github.com/elastic/detection-rules
- **Sigma Rules (GitHub):** https://github.com/SigmaHQ/sigma

End of Report · CyArt Documentation Format ·